[기관 로고]

기밀 / CONFIDENTIAL

웹 취약점 진단

# 결과 보고서

| | |
|---|---|
| 대상 기관 | {{기관명}} |
| 수행 기관 | {{수행기관명}} |
| 작 성 일 | {{작성일}} |
| 문서 버전 | {{문서버전}} |
| 문서 등급 | {{문서등급}} |

본 문서는 편집용 템플릿입니다. 모든 [대괄호] 항목을 실제 내용으로 교체하여 사용하십시오.

# 목 차


**1. 개요** 4

1) 목적 4

2) 문서 통제 및 진단 조건 4

3) 수행 범위 4

4) 대상 5

5) 일정 5

6) 수행 인력 5

7) 수행 장소 5

**2. 웹 취약점 진단 개요** 6

1) 점검 기준 6

2) 진단 절차 6

3) 활용 도구 6

4) 위험도 기준 7

5) 점검 체크리스트 7

**3. 웹 취약점 진단 결과 요약** 9

1) 전체 취약점 요약 9

2) 위험도별 현황 9

3) 대상별 결과 요약 10

4) 총평 10

5) 조치 우선순위 10

**4. 웹 취약점 진단 상세 결과** 11

1) VUL-001 · {{취약점명}} 11

2) VUL-002 · {{취약점명}} 14

**5. 보호대책** 16

1) 단기 조치 16

2) 중기 조치 16

3) 장기 조치 16

[부록] 상세 점검 체크리스트 17

[부록] 점검 기준 참고표 18

[부록] 추가 증빙 자료 19

## 표 차례

[표 1] 문서 이력 ..... 4
[표 2] 검토 및 승인 ..... 4
[표 3] 진단 전제 및 제한 사항 ..... 4
[표 4] 수행 범위 ..... 4
[표 5] 웹 취약점 진단 대상 ..... 5
[표 6] 절차 및 일정 ..... 5
[표 7] 수행 인력 ..... 5
[표 8] 수행 장소 및 IP 주소 ..... 5
[표 9] 웹 취약점 진단 방법 ..... 6
[표 10] 활용 도구 ..... 6
[표 11] 위험도 기준 ..... 7
[표 12] 웹 취약점 진단 체크리스트 ..... 8
[표 13] 전체 취약점 요약 ..... 9
[표 14] 위험도별 취약점 현황 ..... 9
[표 15] 대상별 결과 요약 ..... 10
[표 16] 조치 우선순위 ..... 10
[표 17] 단기 조치 목록 ..... 16
[표 18] 중기 조치 목록 ..... 16
[표 19] 장기 조치 목록 ..... 16
[표 20] 점검 기준 참고표 ..... 18
[표 21] 취약점 코드 참고표 ..... 18

## 그림 차례

[그림 1] 웹 취약점 진단 절차 흐름도 ..... 6
[그림 2] VUL-001 재현 증빙 화면 ..... 12
[그림 3] VUL-001 추가 증빙 화면 ..... 12
[그림 4] VUL-002 재현 증빙 화면 ..... 15
[그림 5] Appendix C 추가 증빙 화면 (#1) ..... 19
[그림 6] Appendix C 추가 증빙 화면 (#2) ..... 19
[그림 7] Appendix C 추가 증빙 화면 (#3) ..... 19

# 1. 개요

## 1) 목적

*본 웹 취약점 진단은 {{기관명}}의 웹 서비스에 존재하는 보안 취약점을 식별하고, 이에 대한 실증 분석 및 대응방안을 제시함으로써 정보보호 수준을 제고하는 것을 목적으로 합니다.*

**[보고 대상, 업무 중요도, 결과 활용 목적 등 기관별 목적 문구를 추가 입력하십시오.]**

## 2) 문서 통제 및 진단 조건

문서 이력, 검토 체계 및 진단 수행 전제조건은 아래와 같이 관리합니다.

| 버전 | 작성일 | 작성/수정자 | 변경 내용 |
|---|---|---|---|
| **{{문서버전}}** | **{{작성일}}** | **{{작성자}}** | **[초안 작성 / 취약점 결과 반영 / 제출본 확정 등 실제 변경 이력을 입력하십시오.]** |

[표 1] 문서 이력

| 구분 | 소속/부서 | 성명 | 상태 | 비고 |
|---|---|---|---|---|
| 작성 | **{{수행기관}}** | **{{작성자}}** | **[작성 완료]** | *[초안 작성자 또는 책임 컨설턴트 입력]* |
| 검토 | **{{검토부서}}** | **{{검토자}}** | **[검토 예정/완료]** | *[기술 검토, 품질 검토 등 검토 성격 입력]* |
| 승인 | **{{승인부서}}** | **{{승인자}}** | **[승인 예정/완료]** | *[제출 승인권자 또는 고객 승인 여부 입력]* |

[표 2] 검토 및 승인

| 구분 | 내용 | 적용 여부 |
|---|---|---|
| 진단 전제 조건 | **[진단 대상 URL, 허용된 진단 시간대, 네트워크 접근 조건, 테스트용 계정 제공 여부 등을 입력하십시오.]** | *[적용]* |
| 제외 범위 | **[운영 영향 우려로 제외한 기능, 결제/배치/외부연계 시스템 등 제외 범위를 명시하십시오.]** | *[해당 시 입력]* |
| 제한 사항 | **[CAPTCHA, WAF, 접근제어, 테스트 데이터 부족 등 결과 해석에 영향을 주는 제한 사항을 입력하십시오.]** | *[해당 시 입력]* |

[표 3] 진단 전제 및 제한 사항

## 3) 수행 범위

본 진단은 아래 범위를 기준으로 수행되었습니다.

| 범위 구분 | 내용 |
|---|---|
| 진단 유형 | 웹 애플리케이션 취약점 진단 |
| 진단 방식 | 블랙박스 기반 점검 |
| 진단 계정 | **[일반 사용자 계정 / 관리자 계정 / 비인가 상태 등 실제 계정 조건을 입력하십시오.]** |
| 진단 환경 | **[진단망, 로컬 테스트 환경, 프록시 구성 등 실제 수행 환경을 입력하십시오.]** |

[표 4] 수행 범위

## 4) 대상

| 번호 | 시스템명 | 대상 URL | 계정 수준 | 비고 |
|---|---|---|---|---|
| 1 | **{{시스템명}}** | **{{대상URL}}** | *[일반/관리자]* | *[운영/개발, API 포함 여부 등 비고 입력]* |
| 2 | **{{시스템명}}** | **{{대상URL}}** | *[비인가/일반/관리자]* | *[필요 시 추가 대상 정보를 입력하십시오.]* |

[표 5] 웹 취약점 진단 대상

## 5) 일정

| 절차 | 일정 | 산출물 | 내용 |
|---|---|---|---|
| 사전 준비 | **{{사전준비일정}}** | 진단계획 | 범위 선정, 계정 확인, 테스트 환경 점검, 커뮤니케이션 체계 확정 |
| 취약점 진단 | **{{진단기간}}** | 점검 결과 | 웹 취약점 진단, 취약 여부 검증, 재현 로그 및 증빙 확보 |
| 보고서 작성 | **{{보고서작성일}}** | 보고서 초안 | 취약점별 상세 내용, 영향 범위, 대응 권고안 및 증빙 정리 |
| 결과 보고 | **{{결과보고일}}** | 최종본 | 결과 설명, 조치 우선순위 협의, 재점검 계획 공유 |

[표 6] 절차 및 일정

## 6) 수행 인력

| 소속 | 성명 | 역할 | 책임 범위 | 연락처 |
|---|---|---|---|---|
| **{{수행기관}}** | **{{성명}}** | **{{PM/진단책임자}}** | *[범위 승인, 결과 검토, 대외 보고 등 책임 범위를 입력하십시오.]* | **{{이메일/전화}}** |
| **{{수행기관}}** | **{{성명}}** | **{{컨설턴트}}** | *[취약점 재현, 증빙 정리, 대응 권고안 작성 등 입력]* | **{{이메일/전화}}** |

[표 7] 수행 인력

## 7) 수행 장소

| 장소 | 주소 | 진단 IP | 접속 방식 | 비고 |
|---|---|---|---|---|
| **{{수행장소명}}** | **{{주소}}** | **{{진단IP}}** | *[사내망/VPN/원격]* | *[방화벽 예외, 망 분리 여부 등 입력]* |

[표 8] 수행 장소 및 IP 주소

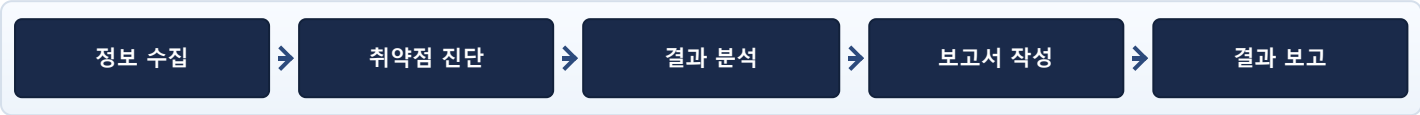
# 2. 웹 취약점 진단 개요

## 1) 점검 기준

본 웹 취약점 진단은 「주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드」와 OWASP Top 10 2021을 기본 기준으로 활용하였으며, 서비스 특성과 인증/인가 흐름을 고려하여 수동 검증 항목을 추가 반영하였습니다.

> 참고 기준: 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드 / OWASP Top 10 2021 / 기관 내부 보안 요구사항

## 2) 진단 절차




[그림 1] 웹 취약점 진단 절차 흐름도

| 절차 | 수행 내용 |
|---|---|
| 정보 수집 | 대상 시스템 정보 수집, 인증 구조 파악, 테스트 계정/시나리오 및 진단 환경 구성 |
| 취약점 진단 | 체크리스트 기반 점검, 요청/응답 분석, 기능별 수동 검증 및 자동화 도구 보조 점검 |
| 결과 분석 | 발견 취약점의 재현 가능성, 영향 범위, 악용 조건 및 판정 근거 분석 |
| 보고서 작성 | 취약점별 상세 설명, 재현 절차, 증빙, 대응 방안, 재점검 기준 정리 |
| 결과 보고 | 발견 사항 공유, 조치 우선순위 협의, 재점검 범위 및 일정 조율 |

[표 9] 웹 취약점 진단 방법

## 3) 활용 도구

| 도구명 | 용도 | 비고 |
|---|---|---|
| Burp Suite Community Edition | 웹 요청/응답 분석, 세션/헤더 검토, 수동 취약점 재현 | 프록시 및 Repeater 중심 사용 |
| HexStrike AI | 점검 자동화 및 결과 분석 보조 | 연계 도구 기반 자동화 프레임워크 |
| Nuclei | 템플릿 기반 취약점 점검 | 보조 점검 도구 |
| FFuf | 디렉터리 및 입력 포인트 탐색 | 콘텐츠 탐색 |
| HTTPx | 웹 서비스 식별 및 응답 확인 | 대상 URL 확인 |
| Nikto | 웹 서버 설정 및 노출 항목 점검 | 서버 구성 점검 |
| 브라우저 개발자 도구 | 프론트엔드 동작 및 네트워크 요청 분석 | 클라이언트 측 확인 |
| 수동 점검(Manual Testing) | 인증, 인가, 세션, 비즈니스 로직 검증 | 핵심 검증 절차 |

[표 10] 활용 도구

## 4) 위험도 기준

본 보고서의 최종 위험도는 취약점 파급도, 공격 난이도, 악용 선행조건, 영향 범위를 종합적으로 고려하여 판정합니다.

| 위험도 | 판정 기준 | 표기 |
|---|---|---|
| **상(High)** | 인증 우회, 권한 상승, 민감정보 탈취, 시스템 침해 등 직접적인 보안 사고로 이어질 수 있는 경우 | 상 |
| **중(Medium)** | 조건부 악용이 가능하거나 추가 조합이 필요한 경우로서 단기 내 조치가 필요한 경우 | 중 |
| **하(Low)** | 직접적 피해 가능성은 낮으나 보안 강화 및 오남용 예방 관점에서 개선이 필요한 경우 | 하 |
| **양호** | 취약점이 확인되지 않았으며 보안 요구사항을 충족하는 경우 | 양호 |

[표 11] 위험도 기준

## 5) 점검 체크리스트

아래 체크리스트는「주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드」기반 21개 항목입니다.

> ※ 본 표의 "기본 위험도(예시)"는 항목 성격에 따른 참조값이며, 최종 위험도는 상세 결과에서 실제 재현 결과와 영향 범위를 기준으로 판정합니다.

| 코드 | 항목명 | 점검 포인트 | 기본 위험도(예시) | 결과 |
|---|---|---|---|---|
| CI | 코드 인젝션 | LDAP/OS명령/SSI 등 코드 실행 구문 삽입 후 비인가 실행 가능 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| SI | SQL 인젝션 | 입력값 조작으로 데이터베이스 오류, 정보 노출, 우회 가능 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| DI | 디렉터리 인덱싱 | 디렉터리 URL 직접 접근 시 목록 노출 여부 및 접근통제 상태 점검 | 상 | *[양호/취약/해당 없음]* |
| EP | 에러 페이지 적용 미흡 | 예외 상황 유발 시 스택 트레이스, 경로, 시스템 정보 노출 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| IL | 정보 누출 | 응답 헤더, 주석, 소스코드, 백업 파일 등에 민감 정보 노출 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| XS | 크로스사이트 스크립팅 | 입력/출력 구간에서 스크립트 삽입, 저장/반사/DOM 기반 실행 가능 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| CF | CSRF | 상태 변경 요청에 대한 CSRF 토큰, Origin/Referer 검증 적용 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| SF | SSRF | 외부 URL 또는 리소스 참조 기능을 통한 내부망/메타데이터 접근 가능 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| BF | 약한 비밀번호 정책 | 복잡도, 길이, 잠금 정책, 초기 비밀번호 및 재사용 정책 점검 | 상 | *[양호/취약/해당 없음]* |
| IA | 불충분한 인증 절차 | 인증 우회, 세션 없는 접근, 다단계 인증 미적용 등 인증 절차 미흡 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| IN | 불충분한 권한 검증 | 직접 객체 참조, URL 추측, 메뉴 우회 등 권한 외 기능 접근 가능 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| PR | 취약한 비밀번호 복구 | 본인확인 절차, 임시 비밀번호 정책, 토큰 만료/1회성 사용 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| PV | 프로세스 검증 누락 | 다단계 프로세스에서 순서 우회, 파라미터 변조, 승인 없이 완료 가능 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| FU | 악성 파일 업로드 | 확장자/콘텐츠 타입 우회, 실행 가능한 파일 업로드 및 접근 가능 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| FD | 파일 다운로드 | 경로 조작 또는 권한 미검증으로 임의 파일 다운로드 가능 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| IS | 불충분한 세션 관리 | 세션 예측, 고정, 장시간 유지, 로그아웃 후 재사용 가능 여부 점검 | 상 | *[양호/취약/해당 없음]* |

| 코드 | 항목명 | 점검 포인트 | 기본 위험도(예시) | 결과 |
|---|---|---|---|---|
| SN | 데이터 평문 전송 | 로그인 정보, 개인정보, 세션 식별자 등의 암호화 전송 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| CC | 쿠키 변조 | 쿠키 값 변조, Secure/HttpOnly/SameSite 미설정 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| AE | 관리자 페이지 노출 | 관리자 페이지 직접 접근, 경로 추측, 기본 경로 노출 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| AU | 자동화 공격 | 로그인/인증 기능의 반복 시도 제한, CAPTCHA, 이상행위 탐지 여부 점검 | 상 | *[양호/취약/해당 없음]* |
| WM | 불필요한 Method 악용 | PUT, DELETE, TRACE 등 불필요한 HTTP Method 허용 여부 및 제한 정책 점검 | 상 | *[양호/취약/해당 없음]* |

[표 12] 웹 취약점 진단 체크리스트

# 3. 웹 취약점 진단 결과 요약

## 1) 전체 취약점 요약

| 구분 | 점검 항목 수 | 취약 건수 | 양호 건수 | 해당없음 |
|---|---|---|---|---|
| **{{시스템명}}** | *{{총점검항목}}* | *{{취약건수}}* | *{{양호건수}}* | *{{해당없음}}* |
| **{{시스템명}}** | *{{총점검항목}}* | *{{취약건수}}* | *{{양호건수}}* | *{{해당없음}}* |
| **합계** | *{{총점검항목합계}}* | *{{취약합계}}* | *{{양호합계}}* | *{{해당없음합계}}* |

[표 13] 전체 취약점 요약

## 2) 위험도별 현황

| 위험도 | 건수 | 비율 |
|---|---|---|
| 상 | *{{상건수}}* | *{{상비율}}* |
| 중 | *{{중건수}}* | *{{중비율}}* |
| 하 | *{{하건수}}* | *{{하비율}}* |
| 양호 | *{{양호건수}}* | *{{양호비율}}* |
| **합계** | *{{전체건수}}* | ***100%*** |

[표 14] 위험도별 취약점 현황

### 3) 대상별 결과 요약

| 번호 | 시스템명 | 관리번호 | 취약점명 | 위험도 | 상태 |
|---|---|---|---|---|---|
| 1 | **{{시스템명}}** | *{{VUL-001}}* | **{{취약점명}}** | 상 | *{{미조치}}* |
| 2 | **{{시스템명}}** | *{{VUL-002}}* | **{{취약점명}}** | 중 | *{{조치중}}* |

[표 15] 대상별 결과 요약

### 4) 총평

**[예: 총 {{전체취약건수}}건의 취약점이 식별되었으며, 이 중 상 위험도 {{상건수}}건은 인증/인가 또는 민감정보 노출과 직접 연결되므로 우선 조치가 필요합니다. 중·하 위험도 항목은 서비스 영향도를 고려하여 단기/중기 계획에 따라 개선하는 것이 적절합니다.]**

### 5) 조치 우선순위

아래 표는 최종 위험도, 악용 난이도, 영향 범위를 기준으로 조치 순서를 정리한 것입니다.

| 우선순위 | 관리번호 | 취약점명 | 위험도 | 조치 기한 | 담당자 |
|---|---|---|---|---|---|
| 1순위 | *{{VUL-001}}* | **{{취약점명}}** | 상 | *{{즉시}}* | *{{담당자}}* |
| 2순위 | *{{VUL-002}}* | **{{취약점명}}** | 중 | *{{1개월}}* | *{{담당자}}* |

[표 16] 조치 우선순위

# 4. 웹 취약점 진단 상세 결과

※ 아래 블록은 취약점 1건을 실무 제출 수준으로 정리하기 위한 기본 템플릿입니다. 동일 구조를 복사하여 취약점 건수만큼 반복 작성하십시오.

## VUL-001 *{{취약점명}}* 상

### 기본 정보

| | |
|---|---|
| 관리번호 | VUL-001 |
| 대상 시스템 | {{시스템명}} |
| 대상 URL | {{대상URL}} |
| 취약점명 | {{취약점명}} |
| 점검 코드 | {{SI/XS/IN}} |
| 발생 경로 | {{취약경로URL}} |

### 판정 및 조치 현황

| | |
|---|---|
| 진단 결과 | *{{취약}}* |
| 최종 위험도 | 상 |
| 발견일 | {{발견일}} |
| 조치 기한 | {{조치기한}} |
| 조치 상태 | *{{미조치/조치중/완료}}* |
| 담당자 | {{담당자}} |
| 확인자 | {{확인자}} |

**한 줄 요약**
[예: 사용자 입력값에 대한 서버 측 검증이 미흡하여 인증된 사용자가 비인가 데이터에 접근할 수 있는 상태입니다.]

### 취약점 설명

[취약점이 발생하는 기능, 점검 범위, 정상 동작 대비 비정상 동작을 기술하십시오.]

### 발생 원인

[입력값 검증 누락, 서버측 권한 검증 부재, 세션 상태 확인 미흡 등 실제 원인을 입력하십시오.]

### 재현 절차

| | |
|---|---|
| 입력값/파라미터 | {{파라미터명}}={{입력값}} |
| 요청 요약 | {{HTTP Method}}, {{요청경로}}, 주요 헤더/본문 요약 |
| 응답 요약 | [응답 코드, 반환 메시지, 데이터 노출 여부 등 핵심 응답을 요약하십시오.] |
| 주요 증빙 ID | EVD-001, EVD-002 |

1. [사전 조건 확인: 테스트 계정 로그인, 대상 메뉴 진입, 필요한 파라미터 확인]

2. [요청 변조 또는 입력값 삽입: 실제 파라미터/헤더/본문 변경 내용을 입력]

3. [응답 확인: 오류 메시지, 데이터 노출, 권한 우회 여부 등 취약점 성립 근거를 입력]

## 재현 증빙

**증빙 ID: EVD-001** *[로그인 후 요청 변조 결과]*

| | |
|---|---|
| **파라미터/입력값** | *[id=1001, role=user 등 실제 입력값]* |
| **요청/응답 요약** | *[요청 본문과 응답 결과를 2~3문장으로 요약]* |
| **관련 부록** | Appendix C · EVD-001 |

**[증빙 이미지 삽입 — 스크린샷, 패킷 캡처, 도구 출력 결과를 붙여넣으십시오]**

[그림 2] VUL-001 재현 증빙 화면

관련 취약점: VUL-001 / 관련 증빙 ID: **EVD-001**

**증빙 ID: EVD-002** *[추가 응답/데이터 노출 증빙]*

| | |
|---|---|
| **재현 단계** | *[2단계 또는 3단계에서 확인된 추가 근거 입력]* |
| **요청/응답 요약** | *[민감정보 필드, 비인가 응답, 에러 메시지 등 보조 증빙 요약]* |
| **관련 부록** | Appendix C · EVD-002 |

**[보조 증빙 이미지 또는 로그 캡처 삽입]**

[그림 3] VUL-001 추가 증빙 화면

관련 취약점: VUL-001 / 관련 증빙 ID: **EVD-002**

## 영향 범위

**[영향을 받는 사용자 유형, 노출되는 데이터 종류, 악용 시 가능한 행위, 연계 시스템 파급 여부를 기술하십시오.]**

## VUL-001 *{{취약점명}}* 상

상세 결과 계속 · VUL-001

### 위험도 및 판정 근거

**[예: 인증된 일반 사용자가 추가 권한 없이 비인가 데이터에 접근할 수 있고 민감정보 노출이 동반되므로 최종 위험도를 상으로 판정합니다.]**

- 공격 난이도: *[낮음/보통/높음]*
- 영향 자산: *[고객정보/관리기능/API 등]*
- 선행 조건: *[로그인 필요 여부, 특정 권한 필요 여부 등]*

### 대응 방안

1. **[서버측 권한 검증, 입력값 화이트리스트 적용, 출력 인코딩, 보안 설정 강화 등 직접적인 조치 방안을 입력하십시오.]**
2. **[재현 절차에서 사용한 파라미터/기능에 대한 회귀 테스트 포인트를 함께 입력하십시오.]**

### 참고 기준

- *[관련 내부 기준, OWASP 항목, 상세가이드 항목, 보안 코딩 가이드, CVE/CWE 등을 입력하십시오.]*
- *[예: OWASP Top 10 2021 A01, CWE-639, 주요정보통신기반시설 상세가이드 권한검증 항목]*

### 조치 후 재점검 결과

| | |
|---|---|
| **재점검일** | *{{재점검일}}* |
| **재점검 결과** | *[미수행/조치중/해소/부분해소]* |
| **확인 내용** | *[동일 재현 절차 수행 시 더 이상 취약 현상이 발생하지 않는지 확인한 결과를 입력하십시오.]* |
| **비고** | *[관련 이슈 번호, 고객 협의 사항, 운영 영향도, 추가 확인 필요 사항 등을 입력하십시오.]* |

## VUL-002 *{{취약점명}}* 중

### 기본 정보

| | |
|---|---|
| 관리번호 | VUL-002 |
| 대상 시스템 | {{시스템명}} |
| 대상 URL | {{대상URL}} |
| 취약점명 | {{취약점명}} |
| 점검 코드 | {{코드}} |
| 발생 경로 | {{취약경로URL}} |

### 판정 및 조치 현황

| | |
|---|---|
| 진단 결과 | *{{취약}}* |
| 최종 위험도 | 중 |
| 발견일 | {{발견일}} |
| 조치 기한 | {{조치기한}} |
| 조치 상태 | *{{미조치/조치중/완료}}* |
| 담당자 | {{담당자}} |
| 확인자 | {{확인자}} |

### 한 줄 요약

[예: 특정 기능에서 입력값 필터링이 미흡하여 조건부로 비인가 정보 조회가 가능한 상태입니다.]

### 취약점 설명

[취약점이 성립한 기능, 비정상 동작, 서비스 맥락을 입력하십시오.]

### 발생 원인

[유효성 검증 미흡, 출력 인코딩 누락, 권한 체크 누락 등 원인을 기술하십시오.]

### 재현 절차

| | |
|---|---|
| 입력값/파라미터 | {{파라미터명}}={{입력값}} |
| 요청 요약 | [재현에 사용한 요청 경로, 메서드, 주요 입력값을 요약하십시오.] |
| 응답 요약 | [응답 코드, 출력 메시지, 화면 동작 등 취약점 성립 근거를 요약하십시오.] |
| 주요 증빙 ID | EVD-003 |

1. [사전 조건 및 접근 경로 입력]

2. [변조 또는 입력 단계 입력]

3. [응답 확인 및 판정 근거 입력]

## 재현 증빙

**증빙 ID: EVD-003** *[VUL-002 재현 화면]*

| | |
|---|---|
| **재현 단계** | *[취약점 확인에 사용한 단계 번호 및 핵심 입력값]* |
| **요청/응답 요약** | *[응답 메시지, 화면 출력, 비정상 동작 여부 요약]* |
| **관련 부록** | Appendix C · EVD-003 |

**[증빙 이미지 또는 로그 캡처 삽입]**

[그림 4] VUL-002 재현 증빙 화면

관련 취약점: VUL-002 / 관련 증빙 ID: **EVD-003**

## 영향 범위

**[영향을 받는 기능, 사용자 범위, 악용 시 가능한 행위 및 운영 영향도를 기술하십시오.]**

## 위험도 및 판정 근거

**[예: 추가 조건이 필요하나 실제 업무 기능에 영향을 미치므로 최종 위험도를 중으로 판정합니다.]**

- 공격 난이도: *[보통]*
- 영향 자산: *[업무 기능/API/세션 정보]*
- 선행 조건: *[인증 필요/특정 역할 필요 등]*

## 대응 방안

1. **[원인 제거를 위한 직접 조치 방안 입력]**
2. **[조치 후 동일 기능 및 연관 기능 재검증 항목 입력]**

## 참고 기준

- *[관련 내부 기준, 외부 기준, 보안 코딩 규칙, 상세가이드 항목 등을 입력하십시오.]*

## 조치 후 재점검 결과

| | |
|---|---|
| **재점검일** | *{{재점검일}}* |
| **재점검 결과** | *[미수행/조치중/해소/부분해소]* |
| **확인 내용** | *[조치 적용 후 동일 재현 절차 수행 결과를 입력하십시오.]* |
| **비고** | *[고객 협의 사항, 일정 제약, 추가 확인 필요 사항 등을 입력하십시오.]* |

## 5. 보호대책

※ 아래 보호대책은 상세 결과의 최종 위험도와 판정 근거를 바탕으로 단기·중기·장기 조치로 구분한 것입니다.

### 1) 단기 조치 (즉시 ~ 1개월 이내)

| 관리번호 | 취약점명 | 최종 위험도 | 조치 내용 | 담당 부서 | 완료 예정일 | 재점검 기준 |
|---|---|---|---|---|---|---|
| VUL-001 | **{{취약점명}}** | 상 | *[원인 제거 조치, 설정 변경, 코드 수정, 권한 정책 반영 등 즉시 조치 내용을 입력하십시오.]* | *{{담당부서}}* | *{{완료예정일}}* | *[동일 파라미터/기능 재검증, 회귀 테스트 범위 입력]* |

[표 17] 단기 조치 목록

### 2) 중기 조치 (1개월 ~ 3개월 이내)

| 관리번호 | 취약점명 | 최종 위험도 | 조치 내용 | 담당 부서 | 완료 예정일 | 재점검 기준 |
|---|---|---|---|---|---|---|
| *{{VUL-002}}* | **{{취약점명}}** | 중 | *[정책 보강, 검증 로직 정교화, 예외처리 개선 등 중기 조치 내용을 입력하십시오.]* | *{{담당부서}}* | *{{완료예정일}}* | *[조치 후 확인할 재현 절차와 영향 범위를 입력하십시오.]* |

[표 18] 중기 조치 목록

### 3) 장기 조치 (3개월 이상)

| 관리번호 | 취약점명 | 최종 위험도 | 조치 내용 | 담당 부서 | 완료 예정일 | 재점검 기준 |
|---|---|---|---|---|---|---|
| *{{VUL-00N}}* | **{{취약점명}}** | 하 | *[구조 개선, 공통 모듈 적용, 보안 운영 프로세스 보강 등 장기 과제를 입력하십시오.]* | *{{담당부서}}* | *{{완료예정일}}* | *[장기 과제 완료 후 수행할 점검 범위를 입력하십시오.]* |

[표 19] 장기 조치 목록

## 부록 A. 상세 점검 체크리스트

아래 체크리스트는 각 시스템별로 복사하여 사용하십시오.

| 코드 | 항목명 | 점검 방법 요약 | 결과 | 발견 URL | 비고 |
|---|---|---|---|---|---|
| CI | 코드 인젝션 | 입력 파라미터에 인젝션 구문 삽입 후 실행 여부 확인 | *[양호/취약]* | *[URL]* | |
| SI | SQL 인젝션 | SQL 구문 삽입 후 DB 오류 또는 정보 노출 여부 확인 | *[양호/취약]* | | |
| DI | 디렉터리 인덱싱 | 디렉터리 URL 직접 접근 시 목록 출력 여부 확인 | *[양호/취약]* | | |
| EP | 에러 페이지 적용 미흡 | 의도적 오류 유발 후 상세 에러 메시지 노출 여부 확인 | *[양호/취약]* | | |
| IL | 정보 누출 | 응답 헤더, 소스코드, 주석 내 민감 정보 노출 여부 확인 | *[양호/취약]* | | |
| XS | 크로스사이트 스크립팅 | 입력 필드에 스크립트 삽입 후 실행 여부 확인 | *[양호/취약]* | | |
| CF | CSRF | CSRF 토큰 적용 여부 및 위조 요청 성공 여부 확인 | *[양호/취약]* | | |
| SF | SSRF | 외부 URL 파라미터를 통한 내부 요청 여부 확인 | *[양호/취약]* | | |
| BF | 약한 비밀번호 정책 | 단순 패스워드 설정 가능 여부 및 잠금 정책 확인 | *[양호/취약]* | | |
| IA | 불충분한 인증 절차 | 인증 우회 가능 여부 확인 | *[양호/취약]* | | |
| IN | 불충분한 권한 검증 | 권한 외 페이지/기능 접근 가능 여부 확인 | *[양호/취약]* | | |
| PR | 취약한 비밀번호 복구 절차 | 비밀번호 찾기 기능의 보안 메커니즘 확인 | *[양호/취약]* | | |
| PV | 프로세스 검증 누락 | 결제·인증 등 다단계 프로세스 우회 가능 여부 확인 | *[양호/취약]* | | |
| FU | 악성 파일 업로드 | 웹셸 등 악성 파일 업로드 및 실행 가능 여부 확인 | *[양호/취약]* | | |
| FD | 파일 다운로드 | 경로 조작을 통한 임의 파일 다운로드 가능 여부 확인 | *[양호/취약]* | | |
| IS | 불충분한 세션 관리 | 세션 고정·예측·만료 미흡 여부 확인 | *[양호/취약]* | | |
| SN | 데이터 평문 전송 | HTTP 사용 여부 및 중요 데이터 평문 전송 여부 확인 | *[양호/취약]* | | |
| CC | 쿠키 변조 | Secure/HttpOnly 플래그 미설정 및 쿠키 변조 가능 여부 | *[양호/취약]* | | |
| AE | 관리자 페이지 노출 | /admin, /manager 등 관리자 URL 직접 접근 가능 여부 | *[양호/취약]* | | |
| AU | 자동화 공격 | 로그인 실패 횟수 제한, CAPTCHA 적용 여부 확인 | *[양호/취약]* | | |
| WM | 불필요한 Method 악용 | OPTIONS, PUT, DELETE 등 허용 Method 확인 | *[양호/취약]* | | |

## 부록 B. 점검 기준 참고표

본 진단에 적용된 점검 기준 및 참고 자료 목록입니다.

| 구분 | 기준/참고자료명 | 발행기관 | 버전/연도 |
|---|---|---|---|
| 가이드라인 | 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드 | *{{발행기관}}* | *{{연도/버전}}* |
| 국제표준 | OWASP Top 10 2021 | OWASP Foundation | 2021 |
| *[추가]* | *{{기준명}}* | *{{발행기관}}* | *{{연도}}* |

[표 20] 점검 기준 참고표

### 취약점 코드 참고표

※ 아래 위험도는 분류 참고용 예시이며, 최종 위험도는 상세 결과에서 실제 영향 범위와 재현 결과를 기준으로 판정합니다.

| 코드 | 항목명 (한) | 항목명 (영) | 기본 위험도(예시) |
|---|---|---|---|
| CI | 코드 인젝션 | Code Injection | 상 |
| SI | SQL 인젝션 | SQL Injection | 상 |
| DI | 디렉터리 인덱싱 | Directory Indexing | 상 |
| EP | 에러 페이지 적용 미흡 | Improper Error Page | 상 |
| IL | 정보 누출 | Information Leakage | 상 |
| XS | 크로스사이트 스크립팅 | Cross-Site Scripting (XSS) | 상 |
| CF | 크로스사이트 요청 위조 | Cross-Site Request Forgery (CSRF) | 상 |
| SF | 서버사이드 요청 위조 | Server-Side Request Forgery (SSRF) | 상 |
| BF | 약한 비밀번호 정책 | Weak Password Policy | 상 |
| IA | 불충분한 인증 절차 | Insufficient Authentication | 상 |
| IN | 불충분한 권한 검증 | Insufficient Authorization | 상 |
| PR | 취약한 비밀번호 복구 절차 | Weak Password Recovery | 상 |
| PV | 프로세스 검증 누락 | Process Validation Failure | 상 |
| FU | 악성 파일 업로드 | Malicious File Upload | 상 |
| FD | 파일 다운로드 | File Download | 상 |
| IS | 불충분한 세션 관리 | Insufficient Session Management | 상 |
| SN | 데이터 평문 전송 | Sensitive Data Exposure | 상 |
| CC | 쿠키 변조 | Cookie Manipulation | 상 |
| AE | 관리자 페이지 노출 | Admin Page Exposure | 상 |
| AU | 자동화 공격 | Automated Attack | 상 |
| WM | 불필요한 Method 악용 | Unnecessary HTTP Method | 상 |

[표 21] 취약점 코드 참고표

## 부록 C. 추가 증빙 자료

※ 본 섹션은 본문 상세 결과와 분리하여 관리해야 하는 추가 증빙 자료를 정리하는 영역입니다. 각 증빙은 증빙 ID, 관련 취약점 관리번호, 제목, 설명을 함께 기록하십시오.

### 증빙 ID: EVD-001

*[관련 취약점: VUL-001]*

| | |
|---|---|
| **제목** | **{{증빙제목}}** |
| **관련 취약점** | VUL-001 |
| **증빙 구분** | *[스크린샷/패킷 로그/응답 본문/도구 출력]* |
| **본문 참조** | 4장 상세 결과 · EVD-001 |

**[추가 증빙 이미지 또는 캡처 삽입 — 스크린샷, 패킷 로그, 도구 결과 등]**

[그림 5] Appendix C 추가 증빙 화면 (#1)

**설명: [해당 증빙이 어떤 재현 단계와 연결되는지, 본문에서 설명되지 않은 보조 근거가 무엇인지 입력하십시오.]**

### 증빙 ID: EVD-002

*[관련 취약점: VUL-001]*

| | |
|---|---|
| **제목** | **{{증빙제목}}** |
| **관련 취약점** | VUL-001 |
| **증빙 구분** | *[스크린샷/패킷 로그/응답 본문/도구 출력]* |
| **본문 참조** | 4장 상세 결과 · EVD-002 |

**[추가 증빙 이미지 또는 캡처 삽입]**

[그림 6] Appendix C 추가 증빙 화면 (#2)

**설명: [보조 응답 전문, 데이터 노출 범위, 추가 파라미터 근거 등을 입력하십시오.]**

### 증빙 ID: EVD-003

*[관련 취약점: VUL-002]*

| | |
|---|---|
| **제목** | **{{증빙제목}}** |
| **관련 취약점** | VUL-002 |
| **증빙 구분** | *[스크린샷/패킷 로그/응답 본문/도구 출력]* |
| **본문 참조** | 4장 상세 결과 · EVD-003 |

**[추가 증빙 이미지 또는 캡처 삽입]**

[그림 7] Appendix C 추가 증빙 화면 (#3)

**설명: [별도 첨부해야 하는 로그, 추가 확인 결과, 재점검 비교 화면 등을 입력하십시오.]**